



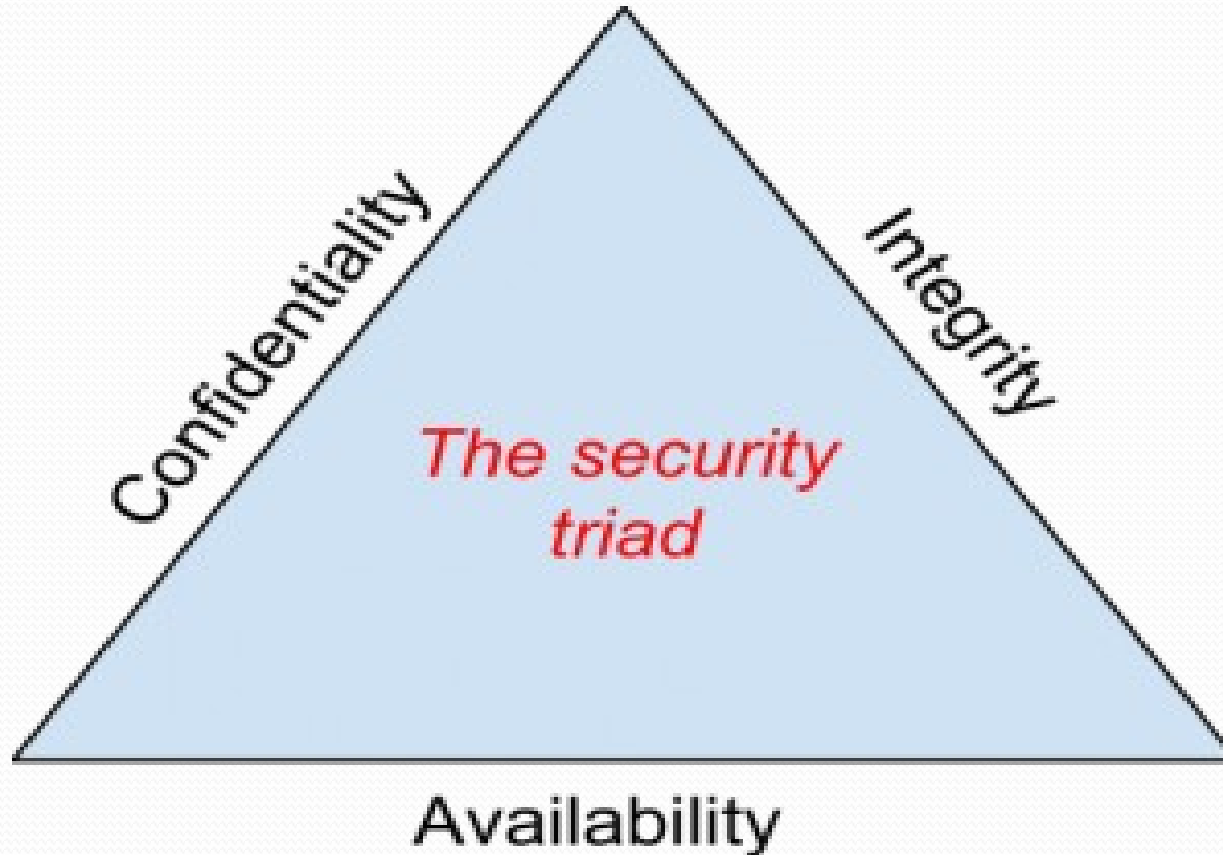
CHAPTER SIX

ETHICAL AND SECURITY ISSUES

INFORMATION SYSTEMS SECURITY

- As computers and other digital devices have become essential to business and commerce, they have also increasingly become a target for attacks.
- In order for a company or an individual to use a computing device with confidence, they must first be assured that the device is not compromised in any way and that all communications will be secure.

The Information Security Triad: Confidentiality, Integrity, Availability (CIA)



1. Confidentiality

- When protecting information, we want to be able to restrict access to those who are allowed to see it; everyone else should be disallowed from learning anything about its contents.
- This is the essence of confidentiality.
- For example, federal law requires that universities restrict access to private student information. The university must be sure that only those who are authorized have access to view the grade records.

2. Integrity

- Integrity is the assurance that the information being accessed has not been altered (changed) and truly represents what is intended.
- Information integrity means information truly represents its intended meaning.
- Information can lose its integrity through malicious intent, such as when someone who is not authorized makes a change to intentionally misrepresent something.

- 
- An example of this would be when a hacker is hired to go into the university's system and change a grade.
 - Integrity can also be lost unintentionally, such as when a computer power surge corrupts a file or someone authorized to make a change accidentally deletes a file or enters incorrect information.

3. Availability

- *Availability* means that information can be accessed and modified by anyone authorized to do so in an appropriate timeframe.
- Companies such as Amazon.com will require their servers to be available twenty-four hours a day, seven days a week. Other companies may not suffer if their web servers are down for a few minutes once in a while.

Tools for Information Security

- In order to ensure the confidentiality, integrity, and availability of information, organizations can choose from a variety of tools.
- Each of these tools can be utilized as part of an overall information-security policy. These tools are discussed in the following sections:

1. Authentication

- The most common way to identify someone is through their physical appearance, but how do we identify someone sitting behind a computer screen or at the ATM?
- Tools for authentication are used to ensure that the person accessing the information is, indeed, who they present themselves to be.
- Authentication can be accomplished by identifying someone through one or more of three factors: **something they know**, **something they have**, or **something they are**.

- For example, the most common form of authentication today is the user ID and password.
- In this case, the authentication is done by confirming something that the user knows (their ID and password).
- But this form of authentication is easy to compromise and stronger forms of authentication are sometimes needed.
- Identifying someone only by something they have, such as a key or a card, can also be problematic. When that identifying token is lost or stolen, the identity can be easily stolen.

- 
- The final factor, something you are, is much harder to compromise.
 - This factor identifies a user through the use of a physical characteristic, such as an eye-scan or fingerprint.
 - Identifying someone through their physical characteristics is called *biometrics*.

2. Access Control

- Once a user has been authenticated, the next step is to ensure that they can only access the information resources that are appropriate.
- This is done through the use of access control.
- Access control determines which users are authorized to read, modify, add, and/or delete information.

3. Encryption

- Many times, an organization needs to transmit information over the Internet or transfer it on external media such as a CD or flash drive. In these cases, even with proper authentication and access control, it is possible for an unauthorized person to get access to the data.
- *Encryption is a process of encoding data upon its transmission or storage so that only authorized individuals can read it.*
- This encoding is accomplished by a computer program, which encodes the plain text that needs to be transmitted; then the recipient receives the cipher text and decodes it (decryption).

Password Security

- Why is using just a simple user ID/password not considered a secure method of authentication?
- It turns out that this single-factor authentication is extremely easy to compromise.
- Good password policies must be put in place in order to ensure that passwords cannot be compromised.
- Below are some of the more common policies that organizations should put in place.

- *Require complex passwords:* One reason passwords are compromised is that they can be easily guessed.
- A recent study found that the top three passwords people used in 2012 were *password*, *123456* and *12345678*.
- A password should not be simple, or a word that can be found in a dictionary.
- One of the first things a hacker will do is try to crack a password by testing every term in the dictionary! Instead, a good password policy is one that requires the use of a minimum of *eight characters*, and at least *one upper-case* letter, *one special character*, and *one number*.

- *Change Passwords Regularly.* It is essential that users change their passwords on a regular basis.
- Users should change their passwords every **sixty** to **ninety** days, ensuring that any passwords that might have been stolen or guessed will not be able to be used against the company.

- *Train employees not to give away passwords:*
- One of the primary methods that is used to steal passwords is to simply figure them out by asking the users or administrators.
- Pretesting occurs when an attacker calls a helpdesk or security administrator and pretends to be a particular authorized user having trouble logging in.
- Then, by providing some personal information about the authorized user, the attacker convinces the security person to reset the password and tell him what it is.

- 
- Another way that employees may be tricked into giving away passwords is through *e-mail phishing*.
 - Phishing occurs when a user receives an e-mail that looks as if it is from a trusted source, such as their bank, or their employer.
 - In the e-mail, the user is asked to click a link and log in to a website that mimics the genuine website and enter their ID and password, which are then captured by the attacker.

Backups

- Another essential tool for information security is a comprehensive backup plan for the entire organization.
- Not only should the data on the corporate servers be backed up, but individual computers used throughout the organization should also be backed up.
- A good backup plan should consist of several components.
- *Regular backups of all data:* Critical data should be backed up daily, while less critical data could be backed up weekly.

- **Offsite storage of backup data sets:** If all of the backup data is being stored in the same facility as the original copies of the data, then a single event, such as an earthquake, fire, or tornado, would take out both the original data and the backup!
- It is essential that part of the backup plan is to store the data in an offsite location.
- **Test of data restoration:** On a regular basis, the backups should be put to the test by having some of the data restored.
- This will ensure that the process is working and will give the organization confidence in the backup plan.

- 
- Besides these considerations, organizations should also examine their operations to determine what effect downtime would have on their business.
 - If their information technology were to be unavailable for any sustained period of time, how would it impact the business?

Additional concepts related to backup include the following:

- **Universal Power Supply (UPS):** A UPS is a device that provides battery backup to critical components of the system, allowing them to stay online longer and/or allowing the IT staff to shut them down using proper procedures in order to prevent the data loss that might occur from a power failure.
- **Alternate, or “hot” sites:** Some organizations choose to have an alternate site where an exact replica of their critical data is always kept up to date. When the primary site goes down, the alternate site is immediately brought online so that little or no downtime is experienced.

Firewalls

- Another method that an organization should use to increase security on its network is a firewall. A firewall can exist as hardware or software (or both).
- A hardware firewall is a device that is connected to the network and filters the packets based on a set of rules.
- A software firewall runs on the operating system and intercepts packets as they arrive to a computer.

- A firewall protects all company servers and computers by stopping packets from outside the organization's network that do not meet a strict set of criteria.
- A firewall may also be configured to restrict the flow of packets leaving the organization. This may be done to eliminate the possibility of employees watching *YouTube* videos or using *Facebook* from a company computer.

Physical Security

- An organization can implement the best authentication scheme in the world, develop the best access control, and install firewalls and intrusion prevention, but its security cannot be complete without implementation of physical security.
- Physical security is the protection of the actual hardware and networking components that store and transmit information resources.
- To implement physical security, an organization must identify all of the vulnerable resources and take measures to ensure that these resources cannot be physically tampered with or stolen. These measures include the following.

- ***Locked doors:*** It may seem obvious, but all the security in the world is useless if an intruder can simply walk in and physically remove a computing device. High-value information assets should be secured in a location with limited access.
- ***Physical intrusion detection:*** High-value information assets should be monitored through the use of security cameras and other means to detect unauthorized access to the physical locations where they exist.
- ***Secured equipment:*** Devices should be locked down to prevent them from being stolen. One employee's hard drive could contain all of your customer information, so it is essential that it be secured.

- ***Environmental monitoring:*** An organization's servers and other high-value equipment should always be kept in a room that is monitored for temperature, humidity, and airflow. The risk of a server failure rises when these factors go out of a specified range.
- ***Employee training:*** One of the most common ways thieves steal corporate information is to steal employee laptops while employees are traveling. Employees should be trained to secure their equipment whenever they are away from the office.

Mobile Security

- One of the first questions an organization must consider is whether to allow mobile devices in the workplace at all.
- Many employees already have these devices, so the question becomes:
- Should we allow employees to bring their own devices and use them as part of their employment activities? Or should we provide the devices to our employees? Creating a BYOD (“Bring Your Own Device”) policy allows employees
 - to *integrate themselves more fully into their job* and
 - can bring *higher employee satisfaction* and
 - *productivity*.

- 
- In many cases, it may be virtually impossible to prevent employees from having their own smartphones or iPads in the workplace.
 - If the organization provides the devices to its employees, it gains more control over use of the devices, but it also exposes itself to the possibility of an administrative (and costly) mess.

- Mobile devices can pose many unique security challenges to an organization.
- Probably one of the biggest concerns is theft of intellectual property.
- For an employee with malicious intent, it would be a very simple process to connect a mobile device either to a computer via the USB port, or wirelessly to the corporate network, and download confidential data.
- It would also be easy to secretly take a high-quality picture using a built-in camera.

- 
- When an employee does have permission to access and save company data on his or her device, a different security threat emerges: that device now becomes a target for thieves.
 - Theft of mobile devices (in this case, including laptops) is one of the primary methods that data thieves use.

- So what can be done to secure mobile devices? It will start with a good policy regarding their use.
- According to a 2013 SANS study, organizations should consider developing a mobile device policy that addresses the following issues:
 - *use of the camera, use of voice recording,*
 - *application purchases, encryption at rest,*
 - *Wi-Fi auto connect settings, Bluetooth settings, VPN use,*
 - *password settings, lost or stolen device reporting,* and
 - *backup.*

Personal Information Security

- The last point we have to raise about security is that what measures each of us, as individual users, can take to secure our computing technologies. There is no way to have 100% security, but there are several simple steps we, as individuals, can take to make ourselves more secure.
- **Keep your software up to date:** Whenever a software vendor determines that a security flaw has been found in their software, they will release an update to the software that you can download to fix the problem.
- Turn on automatic updating on your computer to automate this process.

- 
- ***Install antivirus software and keep it up to date:*** There are many good antivirus software packages on the market today, including free ones.
 - ***Be smart about your connections:*** You should be aware of your surroundings.
 - When connecting to a Wi-Fi network in a public place, be aware that you could be at risk of being spied on by others sharing that network.

- 
- It is advisable not to access your financial or personal data while attached to a Wi-Fi hotspot. You should also be aware that connecting USB flash drives to your device could also put you at risk.
 - Do not attach an unfamiliar flash drive to your device unless you can scan it first with your security software.

- ***Back up your data:*** Just as organizations need to back up their data, individuals need to as well. And the same rules apply: do it regularly and keep a copy of it in another location.
- ***Secure your accounts with two-factor authentication:*** Most e-mail and social media providers now have a two-factor authentication option.
- The way this works is simple: when you log in to your account from an unfamiliar computer for the first time, it sends you a text message with a code that you must enter to confirm that you are really you.
- This means that no one else can log in to your accounts without knowing your password and having your mobile phone with them.

- ***Make your passwords long, strong, and unique:*** For your personal passwords, you should follow the same rules that are recommended for organizations. Your passwords should be long (eight or more characters) and contain at least two of the following: upper-case letters, numbers, and special characters. You also should use different passwords for different accounts, so that if someone steals your password for one account, they still are locked out of your other accounts.

- ***Be suspicious of strange links and attachments:***

When you receive an e-mail, tweet, or Facebook post, be suspicious of any links or attachments included there.

- Do not click on the link directly if you are at all suspicious. Instead, if you want to access the website, find it yourself and navigate to it directly.